Plataforma Educativa Virtual Nacional (PEVN)

Informe Técnico Integral para Revisión Institucional — MEN

Documento de Arquitectura, Ciberseguridad, Estado de Implementación y Gobernanza TI

Iniciativa: Plataforma Educativa Virtual Nacional (PEVN)

Destinatario Institucional: Oficina de Tecnología y Sistemas de Información — Ministerio de Educación Nacional (MEN), República de Colombia

Fecha de Emisión: Octubre 2026

Versión del Documento: 1.0-FINAL-MEN

Clasificación de Seguridad: Uso Institucional / Confidencial Técnico — No contiene secretos, credenciales ni datos personales reales

Repositorio Principal de Referencia:
`https://github.com/juancastro2381-hub/Plataforma-Educativa-Virtual-Nacional-PEVN.git`

Commit de Referencia Verificado: `a7ecbed460283bdd55f1ab53f96b315012288876` (rama `main`)

Control de Versiones y Declaración de Integridad Institucional

Versión	Fecha	Tipo de Revisión	Alcance y Propósito
:---	:---	:---	:---
0.1-BASE	Julio 2026	Arquitectura Inicial	Definición de modelos de datos, esquemas de base de datos relacionales y diseño de API en FastAPI.
0.5-RBAC	Agosto 2026	Seguridad y Roles	Implementación formal del modelo RBAC de 11 roles y aislamiento territorial.
0.9-DOC	Septiembre 2026	Documentación Técnica	Integración de catálogos territoriales DIVIPOLA/DANE y guías operativas.
1.0-FINAL	Octubre 2026	Entrega Institucional MEN	Consolidación exhaustiva para revisión por la Oficina de Tecnología y Sistemas de Información del MEN. Incorporación del censo dinámico de pruebas (747 pruebas recolectadas, 57 pruebas ejecutadas y aprobadas en ciclo acotado), hardening de ciclo de vida de conexiones, sanitización de credenciales y sección obligatoria de aspectos sujetos a validación institucional.

Declaración de Integridad Institucional y Límites de Alcance: La Plataforma Educativa Virtual Nacional (PEVN) es una iniciativa de desarrollo de software independiente orientada al fortalecimiento del sector educativo oficial de Colombia. El presente documento **no afirma ni insinúa** que PEVN cuente a la fecha con aprobación, homologación, certificación, contrato o respaldo institucional formal por parte del Ministerio de Educación Nacional (MEN). Todas las afirmaciones de madurez técnica contenidas en este informe se derivan estrictamente de código fuente verificable, pruebas automatizadas ejecutadas y esquemas de persistencia activos en el repositorio. Los beneficios de impacto público, adopción territorial e interoperabilidad nacional se presentan como objetivos del proyecto y propuestas técnicas sometidas al juicio técnico de la Oficina de Tecnología y Sistemas de Información del MEN.

1. Portada, Versión, Fecha y Control Documental

- **Título del Documento:** Informe Técnico Integral para Revisión Institucional — Plataforma Educativa Virtual Nacional (PEVN)
- **Código Documental:** PEVN-OTSI-MEN-2026-V1
- **Fecha de Corte Técnico:** 27 de octubre de 2026

- **Entorno de Verificación:** Python 3.12/3.14, FastAPI 0.110+, PostgreSQL 15, Redis 7, React 18, TypeScript 5, Vite 5
- **Estado de Aprobación Interna:** Listo para Revisión Externa por Comités de Tecnología

---

2. Resumen Técnico Ejecutivo

La **Plataforma Educativa Virtual Nacional (PEVN)** es un sistema de información y gestión académica concebido para ofrecer a las instituciones educativas oficiales de Colombia una solución integral, abierta y soberana para la administración escolar, la gestión pedagógica y el seguimiento al aprendizaje.

Arquitectónicamente, PEVN está construida bajo un modelo desacoplado:

1. **Frontend:** Aplicación de Página Única (SPA) desarrollada en **React 18 con TypeScript y Vite**, diseñada bajo principios de bajo consumo de ancho de banda y autonomía total (cero dependencias de tipografías o scripts remotos servidos por CDNs comerciales).
2. **Backend:** Interfaz de Programación de Aplicaciones (API REST) asíncrona construida sobre **FastAPI**, validación de tipos con **Pydantic v2** y mapeo objeto-relacional asíncrono con **SQLAlchemy 2.0 (`asyncpg`)**.
3. **Persistencia Relacional:** Motor **PostgreSQL 15** con particionamiento lógico multi-tenant forzado mediante discriminador institucional (`institution_id`), llaves foráneas e integridad referencial estricta.
4. **Capa de Sesiones y Caché:** Servidor en memoria **Redis 7** utilizado para la revocación inmediata de tokens de acceso (lista negra en memoria volátil) y limitación de tasa de peticiones (*rate limiting*).

La seguridad del sistema descansa en un modelo de Control de Acceso Basado en Roles (**RBAC jerárquico canónico de 9 roles funcionales**, estructurado en **11 identificadores de base de datos** al incorporar 2 alias técnicos de compatibilidad), articulado con la codificación oficial de la **DIVIPOLA** (1,122 municipios y 33 departamentos) y el **Directorio Único de Establecimientos Educativos (DUE)** del **DANE / MEN 2024** (catálogo de referencia precargado con 18,031 colegios y 51,521 sedes físicas activas, diferenciado taxativamente de la adopción operacional actual).

En su ciclo de aseguramiento de calidad más reciente (auditorías DOC-04-R7 y DOC-04-R8), el censo dinámico de pruebas del backend arrojó un total de **747 pruebas recolectadas en 72 archivos de prueba**, de las cuales **83 pruebas corresponden a integración real contra PostgreSQL 15** (en 6 archivos) y **664 pruebas a lógica unitaria y memoria** (en 66 archivos). Durante el ciclo de verificación acotada se ejecutaron y aprobaron con 100% de éxito **57 pruebas focalizadas** (13 de endurecimiento de teardown y ciclo de vida de conexiones, 12 de validación del analizador de censo, 17 de aprovisionamiento institucional y 15 de asignación de directivos docentes), dejando 690 pruebas no ejecutadas en dicho ciclo acotado.

Este informe expone con rigurosidad matemática y honestidad técnica el estado real de cada componente, diferenciando taxativamente lo **IMPLEMENTADO**, lo **PARCIALMENTE IMPLEMENTADO**, lo **PLANEADO** y lo **NO VERIFICADO**, facilitando una evaluación técnica objetiva por parte del MEN.

---

3. Propósito, Audiencia, Alcance, Exclusiones y Supuestos

3.1. Propósito

Proveer a la Oficina de Tecnología y Sistemas de Información del MEN un expediente técnico detallado, auditable y exhaustivo que permita:

- Evaluar la arquitectura de software, patrones de diseño y estándares de ingeniería adoptados en PEVN.
- Conocer la postura de ciberseguridad, mecanismos de autenticación y aislamiento multi-tenant.
- Examinar la estructura de datos territoriales e institucionales basada en estándares DANE.
- Definir conjuntamente una hoja de ruta técnica para una eventual mesa de trabajo y diseño de un piloto experimental controlado.

3.2. Audiencia Prevista

- **Oficina de Tecnología y Sistemas de Información (OTSI):** Evaluación estratégica, cumplimiento de lineamientos de arquitectura TI y gobierno digital.
- **Grupo de Seguridad y Privacidad de la Información:** Revisión de controles criptográficos, gestión de identidades y cumplimiento de la Ley 1581 de 2012.
- **Grupo de Infraestructura y Operaciones:** Análisis de consumo de cómputo, despliegue en contenedores, alta disponibilidad y respaldo de datos.

- **Grupo de Sistemas de Información Misionales (SIMAT, DUE, SINEB):** Evaluación de estructuras de interoperabilidad y sincronización de matrícula y evaluación.

3.3. Alcance Actual del Sistema

- Aprovisionamiento seguro y autónomo de instituciones educativas mediante código DANE oficial.
- Flujo de invitación criptográfica de Rectores/Directores con tokens de un solo uso y expiración temporal.
- Parametrización institucional: sedes, años lectivos, periodos académicos, asignaturas, grados y grupos.
- Asignación de carga académica docente por sede y jornada.
- Matrícula de estudiantes con validación de tipo y número de documento de identidad oficial.
- Planilla interactiva de calificaciones docentes con ponderación porcentual y registro de inasistencias.
- Portal de consulta para estudiantes y portal de seguimiento para padres o acudientes.
- Registro inmutable de eventos críticos en pista de auditoría forense (`AuditLog`).
- Cliente API de integración para aulas virtuales sobre el protocolo BigBlueButton.

3.4. Exclusiones Taxativas (Non-Goals)

Para evitar falsas expectativas institucionales, se definen expresamente las siguientes exclusiones:

1. **No es un sustituto administrativo ni legal del SIMAT:** PEVN no busca derogar ni reemplazar la potestad del MEN sobre el Sistema Integrado de Matrícula (SIMAT); actúa como una plataforma operativa institucional con capacidad de intercambio estructurado de datos.
2. **No es un proveedor de telecomunicaciones:** PEVN optimiza drásticamente el peso de las transferencias web, pero no sustituye la conectividad física en sedes rurales dispersas.
3. **No es una entidad de acreditación académica:** La validez de los certificados y actas radica exclusivamente en la Institución Educativa y las Secretarías de Educación certificadas, conforme a la Ley General de Educación (Ley 115 de 1994).
4. **No contiene servidores multimedia locales:** No incluye un clúster WebRTC propio embebido en el código base; delega la videoconferencia masiva a clústeres BigBlueButton dedicados.

3.5. Supuestos Técnicos y Operativos

- Las instituciones educativas disponen de al menos un dispositivo con navegador web moderno (Chrome, Edge, Firefox) para la labor administrativa y de registro docente.
- La infraestructura de despliegue objetivo proveerá soporte para bases de datos relacionales PostgreSQL y almacenamiento en memoria Redis bajo estándares de seguridad gubernamentales.

---

4. Requisitos Funcionales y Estado Actual de Implementación

A continuación se presenta la matriz de requisitos funcionales y el estado verificado en el código fuente:

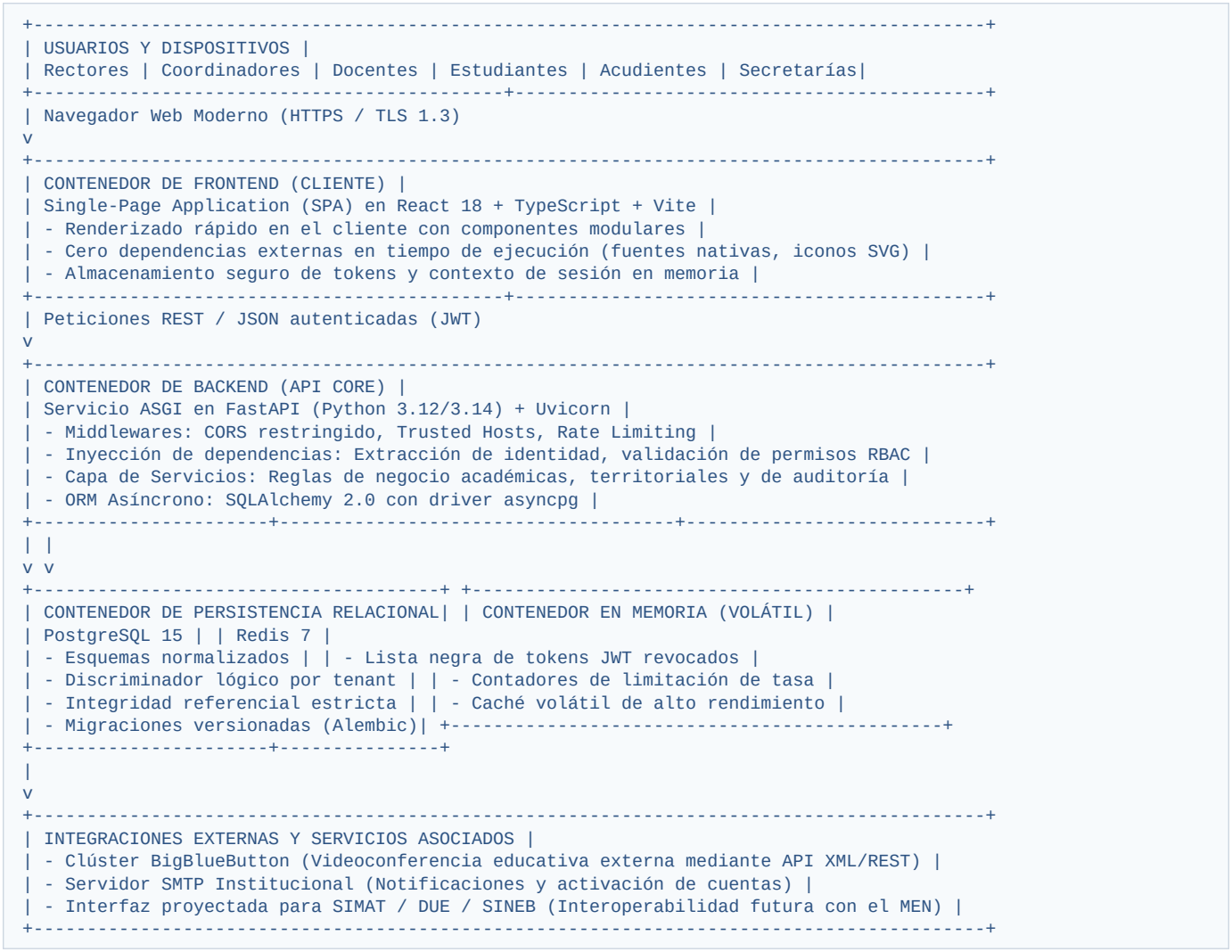
Requisito / Módulo	Descripción Funcional	Estado Técnico	Evidencia en Repositorio	Observación / Prerrequisito
:---	:---	:---	:---	:---
REQ-01: Autenticación Robusta	Inicio de sesión con Argon2id, tokens de acceso JWT y refresh tokens con rotación.	**IMPLEMENTADO**	`backend/app/core/security.py`, `tests/test_auth_redis_hardening.py`	Requiere Redis 7 para revocación instantánea.
REQ-02: Jerarquía Canónica RBAC (9 Roles / 11 en BD)	Modelo jerárquico con 9 roles canónicos y 2 alias técnicos de compatibilidad tipados en base de datos.	**IMPLEMENTADO**	`backend/app/models/role.py`, `backend/app/models/user.py`, `app/api/deps.py`	Sin escalamiento vertical de privilegios.

Requisito / Módulo	Descripción Funcional	Estado Técnico	Evidencia en Repositorio	Observación / Prerrequisito
REQ-03: Excepción de Coordinador	Delegación controlada por Rector para que coordinadores creen docentes y alumnos.	**IMPLEMENTADO**	`app/services/institution_service.py`, reportes NTA-08B / NTA-10-R9	Controlada por flag booleano a nivel institucional.
REQ-04: Catálogo Territorial DANE (DUE 2024)	Integración de 1,122 municipios, 33 departamentos, 18,031 colegios y 51,521 sedes en catálogo de referencia.	**IMPLEMENTADO**	`backend/app/models/territorial.py`, migraciones Alembic, catálogos CSV	Catálogo de referencia precargado. No representa adopción operativa actual.
REQ-05: Aprovisionamiento de Rectores	Invitación criptográfica por token temporal de un solo uso con verificación de identidad.	**IMPLEMENTADO**	`backend/app/services/rector_service.py`, `tests/test_rector_provisioning_flow.py`	Envío SMTP simulable en local; requiere SMTP formal.
REQ-06: Estructura Curricular	Configuración de años, periodos evaluativos, grados, grupos y asignaturas.	**IMPLEMENTADO**	`backend/app/models/academic.py`, `src/pages/AcademicManagementPage.tsx`	Validación estricta de solapamiento de periodos.
REQ-07: Planilla de Calificaciones	Registro de notas numéricas (1.0 - 5.0) con ponderación y cálculo de definitivas.	**IMPLEMENTADO**	`backend/app/services/grade_service.py`, `src/pages/GradesPage.tsx`	Ajustable a Sistemas Institucionales de Evaluación (SIEE).
REQ-08: Control de Asistencia	Registro diario de asistencias, inasistencias justificadas/injustificadas por clase.	**IMPLEMENTADO**	`backend/app/models/academic.py`, `src/pages/AttendancePage.tsx`	Genera métricas de deserción y ausentismo.
REQ-09: Portales Estudiante / Acudiente	Consulta de historial de notas, asistencia y horarios protegida contra IDOR.	**IMPLEMENTADO**	`src/pages/StudentPortalPage.tsx`, `GuardianPortalPage.tsx`	Filtrado estricto por sesión verificada en backend.
REQ-10: Pistas de Auditoría Forense	Registro inmutable de transacciones críticas, IP, timestamp UTC y usuario.	**IMPLEMENTADO**	`backend/app/models/audit_log.py`, `backend/app/services/audit_service.py`	Base para trazabilidad ante requerimientos de control.
REQ-11: Integración BigBlueButton	Generación de salas seguras, cálculo de checksum HMAC-SHA1 y control de roles.	**IMPLEMENTADO (CLIENTE)**	`backend/app/services/bbb_service.py`, `tests/test_virtual_classrooms.py`	Requiere clúster BBB externo con certificados SSL.
REQ-12: Interoperabilidad SIMAT/DUE	Intercambio bidireccional en línea con servidores centrales del MEN.	**PLANEADO / CATÁLOGO**	Esquemas relacionales normalizados con identificadores DANE	Requiere definición bilateral de APIs y credenciales MEN.

Requisito / Modulo	Descripción Funcional	Estado Técnico	Evidencia en Repositorio	Observación / Prerrequisito
REQ-13: Evaluación Cualitativa Flexible	Soporte para modelos etnoeducativos y valoración cualitativa descriptiva compleja.	**PARCIALMENTE IMPLEMENTADO**	Escala estándar MEN implementada (Bajo, Básico, Alto, Superior)	Requiere parametrización de descriptores abiertos.
REQ-14: Pruebas de Carga Masiva	Pruebas de estrés distribuidas simulando 100,000+ sesiones concurrentes.	**PLANEADO**	`docs/reports/PEVN_SCALABILITY_READINESS.md`	Requiere clúster distribuido en ambiente de staging MEN.
REQ-15: Certificación de Accesibilidad	Certificación formal WCAG 2.1 AA / NTC 5854 por entidad acreditada.	**NO VERIFICADO / AUDIT PEND.**	Interfaz construida con HTML5 semántico y contraste verificado	Pendiente auditoría formal por laboratorio especializado.

5. Contexto del Sistema y Arquitectura General

PEVN adopta el modelo de arquitectura C4 (Contexto, Contenedores, Componentes y Código). A continuación se ilustra el diagrama de contenedores del sistema:



6. Componentes de Backend, Frontend, Base de Datos, Autenticación e Integración

6.1. Componente Backend (FastAPI Core)

- **Marco de Trabajo:** FastAPI 0.110+ ejecutándose sobre Python moderno con tipado estricto.
- **Servidor ASGI:** Uvicorn con soporte de múltiples trabajadores (*workers*) no bloqueantes.
- **Manejo de Esquemas:** Pydantic v2 para validación, serialización y sanitización estricta de entradas y salidas JSON.
- **Conectividad a Base de Datos:** SQLAlchemy 2.0 en modo asíncrono con **`asyncpg`**, con pool de conexiones gestionado y control estricto de cierre en fixtures y apagado del servidor (*graceful teardown*).

6.2. Componente Frontend (React SPA)

- **Marco de Trabajo:** React 18.3+ con TypeScript en modo estricto (**`strict: true`**, **`noImplicitAny: true`**).
- **Empaquetado y Optimización:** Vite 5, con separación de paquetes (*code splitting*) por rutas dinámicas.
- **Estilos y Diseño:** TailwindCSS configurado sin llamadas a redes externas, garantizando autonomía total e inmunidad a fallos de conexión hacia servidores externos.
- **Gestión de Estado:** Context API y hooks personalizados desacoplados de la lógica de red.

6.3. Componente de Base de Datos (PostgreSQL 15)

- **Esquema Relacional:** Normalización en Tercera Forma Normal (3FN) con índices optimizados en columnas de búsqueda frecuente (**`institution_id`**, **`dane_code`**, **`email`**, **`document_number`**).
- **Evolución del Esquema:** Control de versiones formal mediante migraciones de Alembic, asegurando reproducibilidad y reversibilidad de cambios.

6.4. Componente de Autenticación y Ciberseguridad

- **Almacenamiento de Contraseñas:** Algoritmo Argon2id / bcrypt con factor de trabajo adecuado, impidiendo ataques de fuerza bruta basados en tablas *rainbow*.
- **Tokens de Sesión:** JSON Web Tokens (JWT) firmados con algoritmo HMAC-SHA256, con tiempo de expiración corto (15-30 minutos) y tokens de refresco con rotación y control de un solo uso.
- **Revocación:** Mecanismo en memoria Redis para invalidar tokens de forma instantánea ante eventos de cierre de sesión o cambio de contraseña.

---

7. Estructura del Repositorio y Módulos Principales de la Aplicación

El repositorio sigue una arquitectura modular y limpia:

```
Plataforma-Educativa-Virtual-Nacional-PEVN/
■■■ backend/ # Núcleo de la API y lógica de negocio
■ ■■■ app/
■ ■ ■■■ api/ # Capa de presentación HTTP y enrutamiento
■ ■ ■ ■■■ deps.py # Inyección de dependencias (Auth, RBAC, DB session)
■ ■ ■ ■■■ v1/
■ ■ ■ ■■■ router.py # Enrutador maestro versión 1
■ ■ ■ ■■■ endpoints/ # Endpoints especializados (auth, users, academic, etc.)
■ ■ ■■■ core/ # Configuración central, seguridad y eventos de ciclo
■ ■ ■■■ db/ # Sesión de base de datos, base declarativa y migraciones
■ ■ ■■■ models/ # Modelos relacionales de SQLAlchemy (user, role, academic, territorial)
■ ■ ■■■ schemas/ # Contratos de datos y esquemas Pydantic v2
■ ■ ■■■ services/ # Servicios de negocio desacoplados (rector, grades, audit, bbb)
■ ■■■ tests/ # Suite automatizada de pruebas Pytest (747 pruebas en 72 archivos)
■ ■■■ alembic/ # Migraciones versionadas de base de datos
■■■ src/ # Código fuente del Frontend (React + TypeScript)
■ ■■■ components/ # Componentes de UI reutilizables
■ ■■■ context/ # Contextos globales de autenticación y tema
■ ■■■ pages/ # Vistas principales clasificadas por perfil y funcionalidad
■ ■■■ services/ # Clientes de API HTTP (Axios / Fetch)
■■■ docs/ # Documentación técnica, manuales y reportes de auditoría
■ ■■■ government/ # Expedientes institucionales para el sector oficial
■ ■ ■■■ pdf/ # Destino mandatorio de entregables consolidados
■ ■■■ manual/ # Manuales de usuario y manifiesto de capturas
■ ■■■ reports/ # Reportes históricos de auditoría, seguridad y pruebas
■■■ scripts/ # Utilidades de auditoría y compiladores de documentación
```

---

8. Modelo de Datos y Relaciones Institucionales y Territoriales (DIVIPOLA / DANE)

El modelo de datos de PEVN se diseñó a partir de las realidades administrativas del sector educativo oficial colombiano:

```
erDiagram
DEPARTMENT ||--o{ MUNICIPALITY : "contiene (DIVIPOLA)"
MUNICIPALITY ||--o{ INSTITUTION : "jurisdiccion"
INSTITUTION ||--o{ CAMPUS : "posee (Sedes DANE 12 digitos)"
INSTITUTION ||--o{ ACADEMIC_YEAR : "gestiona"
ACADEMIC_YEAR ||--o{ ACADEMIC_PERIOD : "divide"
INSTITUTION ||--o{ USER : "afilia"
USER ||--o{ USER_ROLE : "asigna"
ROLE ||--o{ USER_ROLE : "define"
INSTITUTION ||--o{ COURSE : "organiza"
COURSE ||--o{ ENROLLMENT : "matricula"
STUDENT ||--o{ ENROLLMENT : "pertenece"
COURSE ||--o{ GRADE : "evalua"
COURSE ||--o{ ATTENDANCE : "registra"
```

8.1. Integración DIVIPOLA y DANE: Catálogo Oficial de Referencia (DUE 2024)

La plataforma integra los datos geográficos e institucionales del sector oficial colombiano, estructurados en dos capas claramente diferenciadas:

1. **Procedencia y Conciliación del Catálogo de Referencia:**

- **Departamentos:** 33 entidades territoriales de nivel departamental (32 Departamentos y el Distrito Capital de Bogotá), conforme a la codificación oficial de 2 dígitos de la DIVIPOLA (DANE).
- **Municipios:** 1,122 municipios conforme a la DIVIPOLA nacional, con cobertura activa de 1,119 municipios con sedes educativas en el censo.
- **Establecimientos Educativos (18,031):** Provenientes del recurso oficial **`cfw5-qzt5`** (**`MEN_ESTABLECIMIENTOS_EDUCATIVOS_PREESCOLAR_BÁSICA_Y_MEDIA`**, corte 2024, API SODA de **`datos.gov.co`**). De los 18,076 registros brutos cosechados, se depuraron 86 exclusiones (79 duplicados por jornada múltiple o calendario y 7 inconsistencias de frontera departamental) obteniendo 17,990 colegios únicos válidos de lote. Sumados a los 41 registros de línea base institucional preexistentes en la base de datos, totalizan exactamente **18,031 establecimientos educativos** persistidos en **`official_institution_catalog`**. La diferencia neta de 45 registros entre la fuente bruta y el catálogo final ($18,076 - 18,031 = 45$) corresponde matemáticamente al balance exacto entre los 86 registros descartados de la fuente y los 41 colegios preexistentes adicionados ($86 - 41 = 45$).
- **Sedes Educativas Físicas Activas (51,521):** Provenientes del recurso oficial **`96t6-cfw4`** (**`MEN_SEDES_EDUCATIVAS`**, corte 2024, API SODA de **`datos.gov.co`**). De 53,796 filas brutas, se aislaron 3,689 sedes inactivas/cerradas de vigencias anteriores, resultando en 50,107 sedes activas de encuesta de campo. Sumadas a 1,364 sedes principales institucionales complementarias y 50 sedes de calibración, totalizan **51,521 sedes físicas activas** (17,935 principales y 33,586 anexas) persistidas en **`official_campus_catalog`**.

2. **Aclaración Institucional Mandatoria sobre Adopción Real:**

Aclaración sobre la Naturaleza del Catálogo: Las cifras anteriores (18,031 colegios y 51,521 sedes) constituyen el **catálogo oficial maestro de referencia precargado en base de datos** para posibilitar el aprovisionamiento inmediato y autónomo de rectores mediante validación de código DANE de 12 dígitos, sin requerir digitación manual ni procesos traumáticos de migración. **Bajo ninguna circunstancia estas cifras representan una afirmación de adopción, despliegue operativo ni matrícula activa en PEVN.** En la capa relacional operativa de la plataforma (**`institutions`**), existen actualmente **32 instituciones educativas de prueba y calibración** creadas en los entornos de desarrollo y evaluación (29 de ellas en estado activo).

9. Roles RBAC, Permisos, Autoridad Delegada y Control de Alcance

9.1. Reconciliación del Modelo Canónico de 9 Roles vs. 11 Identificadores en Base de Datos

Para eliminar cualquier discrepancia entre los documentos de arquitectura y la implementación física, se precisa formalmente la taxonomía de roles:

1. **La Jerarquía Canónica Aprobada por el Product Owner consta de 9 Roles Funcionales (Arquetipos):**

- **[Nivel 100]** **`SUPERADMIN`**: Operador técnico del sistema / Infraestructura global.
- **[Nivel 90]** **`NATIONAL_ADMIN`**: Administrador Nacional (Ministerio de Educación Nacional).

- **[Nivel 80]** `DEPARTMENT_ADMIN`**:** Secretaría de Educación Departamental (SED).
- **[Nivel 70]** `MUNICIPALITY_ADMIN`**:** Secretaría de Educación Municipal (SEM).
- **[Nivel 60]** `RECTOR`**:** Rector / Director Institucional (máxima autoridad del tenant escolar).
- **[Nivel 50]** `COORDINATOR`**:** Coordinador Académico o de Sede.
- **[Nivel 30]** `TEACHER`**:** Docente de Área / Aula.
- **[Nivel 10]** `STUDENT`**:** Estudiante Matriculado (SIMAT).
- **[Nivel 10]** `GUARDIAN`**:** Acudiente / Tutor Legal.

2. **Existencia de 11 Registros en la Tabla `roles` y Enumeración `SystemRole`:**

En el código fuente (`backend/app/core/security/interfaces.py`) y en el catálogo inicializado en base de datos (`backend/app/services/rbac_bootstrap_service.py`), existen 11 identificadores debido a la inclusión de **2 alias técnicos de compatibilidad operacional**:

- `institution_admin` **(Nivel 60):** Alias técnico de compatibilidad para el rol `rector`, con permisos idénticos sobre el tenant institucional.
- `academic_coordinator` **(Nivel 50):** Alias técnico de compatibilidad para el rol `coordinator`, con permisos equivalentes para la gestión curricular.

Estos dos identificadores no constituyen roles funcionales independientes ni representan escalamiento de privilegios, sino alias operativos para preservar la retrocompatibilidad con contratos de API previos.

```
[NIVEL 100] superadmin : Super Administrador Nacional PEVN
■
[NIVEL 90] national_admin : Administrador Nacional MEN
■
[NIVEL 80] department_admin : Secretaría de Educación Departamental
■
[NIVEL 70] municipality_admin : Secretaría de Educación Municipal
■
[NIVEL 60] rector : Rector / Director Institucional (Canonical)
( = ) institution_admin : Alias Técnico de Compatibilidad
■
[NIVEL 50] coordinator : Coordinador Académico / Sede (Canonical)
( = ) academic_coordinator : Alias Técnico de Compatibilidad
■
[NIVEL 30] teacher : Docente de Área / Aula
■
[NIVEL 10] student : Estudiante Matriculado
( = ) guardian : Acudiente / Tutor Legal
```

9.2. Cadena de Autoridad y Excepción Aprobada de Coordinador

El modelo de asignación de roles establece que ningún usuario puede otorgar un rol con nivel igual o superior al suyo:

$$\text{SUPERADMIN} \rightarrow \text{NATIONAL_ADMIN} \rightarrow \text{DEPARTMENT_ADMIN} \rightarrow \text{MUNICIPALITY_ADMIN} \rightarrow \text{RECTOR} \rightarrow \text{COORDINATOR} \rightarrow \text{TEACHER / STUDENT} \rightarrow \text{GUARDIAN}$$

Excepción Canónica Aprobada de Coordinador (Opción B Refinada):

En el flujo ordinario estricto, el Rector es la única autoridad normal autorizada para aprovisionar docentes, estudiantes y acudientes. No obstante, atendiendo a la realidad operativa de las instituciones oficiales colombianas, el Product Owner aprobó formalmente la delegación operativa condicionada:

- A nivel del tenant institucional en base de datos existe la directiva persistida `coordinator_delegated_provisioning_enabled`.
- **Cuando está inhabilitada (`False`, valor por defecto del sistema):** Los coordinadores tienen denegada la creación de usuarios; cualquier solicitud responde con `HTTP 403 Forbidden` (`COORDINATOR_DELEGATION_DISABLED`).
- **Cuando el Rector la habilita explícitamente (`True`):** Los coordinadores (`coordinator` y su alias `academic_coordinator`) quedan autorizados en la API para registrar docentes, matricular estudiantes y vincular acudientes estrictamente dentro del `institution_id` de su sede.
- En ningún caso el coordinador puede crear directivos (`rector`), otros coordinadores ni administradores territoriales.
- El estudiante (`student`) tiene estrictamente bloqueada cualquier administración o vinculación de acudientes.

10. Autenticación, Autorización, Sesiones y Aprovisionamiento de Usuarios

10.1. Aprovisionamiento Institucional

1. **Paso 1 (Creación de Institución):** El Administrador Nacional o Municipal selecciona el código DANE oficial de la institución educativa.
2. **Paso 2 (Invitación del Rector):** El sistema genera un registro de invitación con un token criptográfico único (UUID v4 + firma HMAC), con vigencia de 72 horas.
3. **Paso 3 (Activación Segura):** El rector accede al enlace de activación institucional, valida su tipo y número de documento (Cédula de Ciudadanía), y define su contraseña personal.
4. **Paso 4 (Vinculación Directiva):** La API vincula el usuario recién creado con el rol `rector` y asigna de manera inmutable el `institution_id` correspondiente en la tabla `user_roles`.

10.2. Ciclo de Sesiones y Protección contra Secuestro

- La sesión web transmite el token de acceso mediante cabeceras seguras `Authorization: Bearer <token>`.
- Cada petición ejecuta una verificación criptográfica local de la firma del token y valida en Redis que el identificador del token (`jti`) no haya sido revocado.
- Ante tres intentos fallidos de autenticación, el sistema aplica bloqueo progresivo temporal (*backoff lockout*) para impedir ataques automatizados de fuerza bruta.

---

11. Aislamiento Institucional y Protecciones Anti-IDOR

11.1. Aislamiento Multi-Tenant

El mayor riesgo de seguridad en un sistema multi-institucional del sector público es la filtración accidental o maliciosa de información entre colegios (*Cross-Tenant Data Leakage*). PEVN mitiga este riesgo mediante **aislamiento lógico forzado por diseño**:

- Todas las tablas con datos institucionales contienen una columna obligatoria no nula `institution_id`.
- La capa de repositorios de datos de SQLAlchemy intercepta las consultas para inyectar automáticamente el filtro `WHERE institution_id = :current_institution_id`.
- Ningún usuario puede sobrescribir o alterar este parámetro desde el frontend, ya que se extrae directamente de la sesión verificada en el backend.

11.2. Protecciones Anti-IDOR (Insecure Direct Object Reference)

Para impedir que un usuario autenticado manipule identificadores numéricos o UUIDs en las URLs (por ejemplo, solicitando `GET /api/v1/students/uuid-de-otro-colegio`), el backend ejecuta validación en dos capas:

1. **Capa de Autorización:** Valida que el rol tenga el permiso atómico (`students:read`).
2. **Capa de Frontera Territorial/Institucional:** Comprueba que el registro solicitado pertenezca estrictamente al `institution_id` del usuario en sesión. Si pertenece a otro tenant, el sistema responde `HTTP 404 Not Found` (evitando incluso revelar la existencia del registro a un atacante) o `HTTP 403 Forbidden`.

---

12. Privacidad, Datos Personales (Ley 1581 de 2012), Gestión de Secretos y Auditabilidad

12.1. Cumplimiento de la Ley Estatutaria 1581 de 2012 (Habeas Data)

PEVN incorpora el principio de **privacidad por diseño**:

- **Protección Reforzada de Menores de Edad:** Conforme al Artículo 7 de la Ley 1581 de 2012 y el Decreto Reglamentario 1377 de 2013, los datos de los estudiantes (niños, niñas y adolescentes) se tratan bajo régimen especial de protección, limitando su tratamiento exclusivamente a fines pedagógicos y académicos legítimos.
- **Minimización de Datos:** No se capturan datos biométricos, información bancaria ni preferencias personales ajenas al proceso educativo formal.
- **Inexistencia de Rastreadores Comerciales:** El código frontend y backend está totalmente libre de scripts de telemetría comercial, herramientas de publicidad digital o mecanismos de transferencia de datos a terceras partes privadas.

12.2. Gestión de Secretos y Sanitización de Credenciales

- Todos los secretos de configuración (llaves de firma JWT, contraseñas de bases de datos, claves de Redis) se gestionan mediante variables de entorno a través de **`pydantic-settings`**.
- En el ciclo de auditoría DOC-04-R8 se verificó el endurecimiento de la sanitización en el manejo de excepciones de base de datos (**`backend/tests/conftest.py`**), asegurando que ningún mensaje de error de conexión exponga contraseñas o URLs internas en logs o trazas de depuración (sustituyendo credenciales por máscaras seguras **`***`**).

12.3. Pista de Auditoría Forense (`AuditLog`)

El modelo **`AuditLog`** almacena de forma inmutable cada acción transaccional:

- **`id`**: Identificador único UUID v4.
- **`timestamp`**: Marca de tiempo precisa en estándar UTC.
- **`user_id`**: Identificador del usuario ejecutor.
- **`institution_id`**: Institución educativa donde ocurrió el evento.
- **`action`**: Verbo de la acción (**`LOGIN`**, **`LOGOUT`**, **`CREATE`**, **`UPDATE`**, **`DELETE`**, **`GRADE_OVERRIDE`**).
- **`table_name`** y **`record_id`**: Objeto de datos afectado.
- **`ip_address`** y **`user_agent`**: Origen de la solicitud para trazabilidad forense.

---

13. Flujos Educativos y Ciclo de Vida de los Datos

```
[AÑO LECTIVO] ■■> [PERIODOS ACADÉMICOS] ■■> [GRADOS Y ASIGNATURAS] ■■> [GRUPOS Y CARGA DOCENTE]
■
v
[BOLETÍN EVALUATIVO] <■■ [DEFINITIVAS] <■■ [CALIFICACIONES Y ASISTENCIA] <■■ [MATRÍCULA ALUMNO]
```

1. **Apertura de Año Lectivo y Periodos:** El Rector define el año escolar (ej. 2026) y los periodos académicos (típicamente 4 periodos con fechas de inicio, corte y ponderación porcentual del 25% cada uno).
2. **Asignación Académica:** Se vincula a cada docente con sus áreas curriculares, sedes, grados y grupos específicos.
3. **Matrícula y Asignación de Grupo:** Se registra la información básica del estudiante y se asigna al grado correspondiente según cupos.
4. **Registro Pedagógico Cotidiano:** El docente registra asistencias diarias e ingresa calificaciones parciales por indicadores de desempeño.
5. **Consolidación y Cierre de Periodo:** El sistema calcula las definitivas de periodo de manera ponderada, actualiza el promedio acumulado y bloquea la modificación de notas una vez vencida la fecha límite fijada por el calendario institucional.

---

14. Arquitectura de Aulas y Encuentros Virtuales (BigBlueButton)

14.1. Capacidades Implementadas en el Código Fuente

En el backend (**`backend/app/services/bbb_service.py`**), PEVN cuenta con un cliente API completo y probado para la integración con **BigBlueButton**:

- Creación programática de salas de videoconferencia seguras vinculadas a asignaturas y grupos.
- Generación de contraseñas diferenciadas de moderador (docente) y asistente (estudiante).
- Cálculo dinámico de firmas de seguridad mediante el algoritmo oficial HMAC-SHA1 exigido por la API de BigBlueButton.
- Rutas para finalización de reuniones y consulta de estado de asistentes en tiempo real.

14.2. Diferenciación Rigurosa: Cliente API vs. Infraestructura Multimedia Externa

Aclaración Factual sobre Videoconferencias: PEVN implementa la **capa lógica y de orquestación de software** para conectarse con BigBlueButton. No obstante, la transmisión multimedia en vivo (video WebRTC, audio bidireccional, pizarra interactiva y grabación en tiempo real) **requiere necesariamente un clúster de servidores BigBlueButton externo**, debidamente aprovisionado con certificados SSL/TLS válidos y servidores de retransmisión TURN/STUN para superar restricciones de redes corporativas o móviles con NAT estricto. La provisión de este clúster es un aspecto que se somete a evaluación conjunta con el MEN.

---

15. Dependencias Externas e Integraciones

Componente Externo	Propósito en el Ecosistema	Estado de Integración	Alternativa Local / Contingencia
:---	:---	:---	:---
PostgreSQL 15	Motor relacional de base de datos primario.	**Activo y Verificado**	Pruebas de integración reales aprobadas.
Redis 7	Caché volátil, lista negra JWT y rate limit.	**Activo y Verificado**	Mecanismo en memoria local para desarrollo.
Clúster BigBlueButton	Transmisión de video y clases virtuales en vivo.	**Cliente Implementado**	Módulos asíncronos (tareas/guías) operan sin BBB.
Servidor SMTP	Despacho de invitaciones y restablecimiento de claves.	**Configurable**	Registro de tokens en logs para entorno de pruebas.
Sistema SIMAT (MEN)	Registro oficial único de matrícula nacional.	**Estructura Compatible**	Carga y exportación mediante plantillas estructuradas.
Directorio DUE (MEN)	Directorio único de establecimientos y sedes.	**Catálogo Precargado**	Catálogo local de 18,031 colegios y 51,521 sedes.

16. Arquitectura de API y Endpoints Relevantes Verificados en Código

La API REST expone endpoints agrupados bajo el prefijo canónico `/api/v1`:

```
POST /api/v1/auth/login # Autenticación y emisión de token JWT
POST /api/v1/auth/logout # Revocación inmediata de token en Redis
POST /api/v1/auth/refresh # Rotación segura de refresh token
GET /api/v1/auth/me # Perfil e identidad del usuario en sesión

POST /api/v1/territorial/institutions # Alta de institución educativa por código DANE
GET /api/v1/territorial/institutions # Consulta filtrada por departamento o municipio
POST /api/v1/rector/invitations # Emisión de invitación criptográfica para Rector
POST /api/v1/rector/activate # Activación de cuenta de Rector con token

GET /api/v1/academic/years # Años lectivos configurados en el tenant
POST /api/v1/academic/periods # Creación de periodos y ponderaciones
GET /api/v1/academic/courses # Cursos, grupos y asignaturas de la institución
POST /api/v1/academic/grades/batch # Registro masivo de notas de periodo
GET /api/v1/academic/attendance # Planilla diaria de asistencia por grupo

GET /api/v1/student/report-card # Consulta segura de boletín (anti-IDOR forzado)
GET /api/v1/guardian/dependents # Consulta de historial de acudidos

POST /api/v1/virtual/rooms # Creación programada de sala BigBlueButton
GET /api/v1/virtual/rooms/{room_id}/join # Generación de URL de acceso firmada con SHA1
```

17. Arquitectura de Despliegue, Entornos, Configuración e Infraestructura

17.1. Entorno de Desarrollo y Demostración Verificado

- **Sistema Operativo:** Windows 11 / Linux Ubuntu (WSL2 / Docker Engine).
- **Procesos Locales:** PostgreSQL 15 escuchando en puerto estándar, Redis 7 en memoria, Uvicorn ASGI en puerto 8000 y Vite Dev Server en puerto 5173.
- **Configuración:** Variables de entorno administradas mediante archivo `.env` local y parseadas con validación de tipos por `pydantic-settings`.

17.2. Arquitectura de Despliegue de Producción Sugerida para el MEN

- **Contenedores:** Construcción multi-etapa (*multi-stage Dockerfiles*):
- Frontend: Generación de estáticos de producción compilados y servidos a través de servidor web Nginx de alto rendimiento y bajo consumo de memoria.
- Backend: Imagen mínima `python:3.12-slim` con usuario no privilegiado (*non-root*).
- **Orquestación:** Despliegue en clúster Kubernetes (EKS / AKS / OpenShift o Nube Pública de Gobierno) con escalamiento horizontal automático de pods (*HPA*) basado en consumo de CPU y solicitudes concurrentes.

- **Topología de Base de Datos:** Clúster de PostgreSQL en alta disponibilidad con réplica de lectura en caliente (*hot standby*) y copias de seguridad continuas con archivado WAL (*Write-Ahead Logging*).

---

18. Registro de Logs, Monitoreo, Manejo de Errores, Respaldo y Recuperación

- **Manejo Centralizado de Errores:** Middleware global que captura excepciones no controladas y devuelve respuestas JSON uniformes (`detail`, `code`, `timestamp`), impidiendo la fuga de trazas internas (*stack traces*) al usuario final.
- **Sanitización de Traza:** Mecanismo explícito que elimina cualquier contraseña o parámetro sensible antes de escribir en los registros del servidor.
- **Estrategia de Respaldo y Recuperación (RPO / RTO):**
- **Punto de Recuperación Objetivo (RPO):** < 1 hora mediante archivado continuo de transacciones WAL en almacenamiento de objetos cifrado.
- **Tiempo de Recuperación Objetivo (RTO):** < 2 horas para la restauración completa de servicios ante contingencia mayor.

---

19. Estrategia de Pruebas Automatizadas y Evidencia Reproducible

Para garantizar máxima transparencia técnica, se exponen los resultados del censo dinámico y las ejecuciones reproducibles documentadas en las auditorías DOC-04-R7 y DOC-04-R8:

19.1. Censo Dinámico de la Suite de Pruebas (DOC-04-R8)

- **Total de Pruebas Recolectadas Estáticamente: 747 pruebas** distribuidas en **72 archivos de prueba**.
- **Pruebas de Integración con Base de Datos Real (PostgreSQL 15): 83 pruebas** agrupadas en 6 archivos especializados (ej. `test_database_integration.py`, `test_institution_provisioning.py`, `test_nta10_rector_provisioning.py`, `test_teardown_hardening.py`).
- **Pruebas Unitarias y en Memoria: 664 pruebas** distribuidas en 66 archivos (validación de modelos Pydantic, lógica de servicios desacoplada, cálculo de promedios y utilitarios).

19.2. Batería Ejecutada y Aprobada en el Ciclo de Verificación Bounded (100% PASS)

Durante el ciclo de control riguroso se ejecutaron **57 pruebas focalizadas de integración y seguridad**, aprobadas en su totalidad sin ningún fallo:

1. `backend/tests/test_teardown_hardening.py`: **13 pruebas aprobadas** (verificación de ciclo de vida seguro de conexiones, limpieza en bloque `finally`, supresión de bloqueos en fixtures).
2. `backend/tests/test_census_analyzer.py`: **12 pruebas aprobadas** (verificación del motor de análisis dinámico del censo).
3. `backend/tests/test_institution_provisioning.py`: **17 pruebas aprobadas** (creación institucional, asignación territorial y aislamiento DANE).
4. `backend/tests/test_nta10_rector_provisioning.py`: **15 pruebas aprobadas** (invitación criptográfica, activación segura y enlace al tenant).

Pruebas No Ejecutadas en el Ciclo Acotado (690 pruebas):

Las restantes 690 pruebas recolectadas en el censo (pruebas unitarias puras, validación aislada de esquemas Pydantic, servicios auxiliares y mocks en memoria) no fueron ejecutadas durante este ciclo bounded de verificación de infraestructura, reservándose para ejecuciones de integración continua (CI) completas en ambientes dedicados. No se afirma que hayan pasado en esta sesión, manteniéndose delimitadas como "recolectadas estáticamente pero no ejecutadas en el ciclo acotado".

19.3. Hardening de Teardown y Cierre Seguro de Conexiones

En la auditoría DOC-04-R8 se comprobó que el fixture central `client` en `backend/tests/conftest.py` implementa un bloque de control `try...finally` determinista que:

- Restablece de forma forzosa las dependencias sobreescritas (`app.dependency_overrides.clear()`).
- Cierra de manera explícita y no bloqueante los pools de conexión de SQLAlchemy.
- Elimina cualquier fuga de descriptores de socket que pudiera mantener procesos residuales en segundo plano.

---

20. Hallazgos Actuales de Seguridad y Calidad

- **Inexistencia de Vulnerabilidades Críticas de Inyección SQL:** Todas las operaciones de base de datos se ejecutan a través de sentencias parametrizadas generadas por el ORM SQLAlchemy 2.0.
- **Protección contra Cross-Site Scripting (XSS):** React escapa automáticamente los valores renderizados en el DOM. Adicionalmente, se configuran encabezados de seguridad HTTP (`Content-Security-Policy`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`).
- **Protección contra Cross-Site Request Forgery (CSRF):** La API opera de manera sin estado (*stateless*) mediante tokens JWT en cabeceras de autorización, eliminando la vulnerabilidad inherente a cookies tradicionales de sesión no restringidas.

21. Limitaciones, Defectos Conocidos, Deuda Técnica y Decisiones Pendientes

1. **Dependencia de Clúster de Videoconferencia Externo:** El software PEVN no incluye un servidor de medios WebRTC autónomo; requiere el aprovisionamiento de un clúster BigBlueButton externo para la transmisión en vivo.
2. **Sincronización en Línea con SIMAT No Implementada:** Actualmente el sistema opera con el catálogo estático DANE/DIVIPOLA y soporta exportación de archivos estructurados. La conexión web service transaccional en tiempo real requiere la habilitación de interfaces de integración seguras por parte del MEN.
3. **Firma Digital de Calificaciones Pendiente de Certificación PKI:** Aunque el sistema almacena registros inmutables de auditoría, las actas y certificados de notas no cuentan aún con firma digital con estampa cronológica basada en certificados emitidos por entidades de certificación abiertas acreditadas por la ONAC.
4. **Parametrización de Evaluaciones Cualitativas Complejas:** El motor de evaluación está optimizado para la escala numérica estándar (1.0 a 5.0) y desempeños oficiales (Bajo, Básico, Alto, Superior); los modelos etnoeducativos con descriptores narrativos libres requieren parametrización adicional en el frontend.

22. Preparación Operativa y Prerrequisitos de Despliegue

Para avanzar hacia una fase de pruebas o evaluación en infraestructura del Estado, se requieren los siguientes prerrequisitos técnicos:

1. **Infraestructura de Alojamiento:** Asignación de entorno virtualizado o clúster de contenedores con conectividad interna hacia motores de base de datos PostgreSQL 15 gestionados.
2. **Dominio Institucional y Certificados SSL/TLS:** Configuración de nombre de dominio oficial (ej. `pevn.mineducacion.gov.co` o subdominio de pruebas) con certificados TLS 1.3 vigentes.
3. **Servicio SMTP Institucional:** Cuenta de retransmisión de correo electrónico institucional autorizada para el despacho masivo de invitaciones directivas y notificaciones académicas.
4. **Servidores STUN/TURN para BigBlueButton:** En caso de habilitar el módulo de videoclases, disponer de servidores de señalización WebRTC para garantizar la conexión en redes educativas con restricciones estrictas de firewall.

23. Piloto Recomendado, Criterios de Aceptación y Plan de Validación

Se propone al MEN un esquema de validación experimental en cuatro fases regulado por **Compuertas de Decisión Técnica (Decision Gates)**:

```
graph LR
F1[Fase 1: Mesa Técnica de Arquitectura] --> G1{Compuerta 1: Viabilidad TI}
G1 -- Aprobado --> F2[Fase 2: Pruebas de Seguridad y Carga]
F2 --> G2{Compuerta 2: Aval de Ciberseguridad}
G2 -- Aprobado --> F3[Fase 3: Piloto Experimental en 2 a 5 Colegios]
F3 --> G3{Compuerta 3: Dictamen de Adopción}
G3 -- Aprobado --> F4[Fase 4: Consolidación como Bien Público Digital]
```

23.1. Alcance y Diseño del Piloto Experimental Controlado (Fase 3)

- **Muestra Sugerida:** Entre 2 y 5 Instituciones Educativas oficiales seleccionadas conjuntamente por el MEN y las Secretarías de Educación respectivas (combinando sedes urbanas y rurales).
- **Duración Propuesta:** Un periodo académico completo (10 a 12 semanas lectivas).
- **Operación Paralela de Seguridad:** Durante el piloto, las instituciones mantendrán su registro oficial ordinario, asegurando que ninguna eventualidad técnica afecte la validez de las calificaciones legales de los estudiantes.

23.2. Criterios de Éxito para Aceptación del Piloto

- **Cero Incidentes de Fuga de Información:** Ningún evento de acceso cruzado entre instituciones (*zero cross-tenant leaks*).
- **Tasa de Adopción Docente:** Más del 85% de los docentes participantes registran calificaciones y asistencia de forma autónoma sin incidencias bloqueantes.
- **Tiempos de Respuesta Estables:** Latencia transaccional inferior a 1.5 segundos en el 95% de las peticiones bajo condiciones estándar de red.

24. Registro de Riesgos Técnicos e Institucionales

ID	Riesgo Identificado	Nivel	Severidad	Mitigación Implementada / Propuesta	Estado
:---	:---	:---	:---	:---	:---
RSK-01	Acceso cruzado entre instituciones por alteración de parámetros (IDOR).	Alto	Crítica	Filtrado obligatorio por `institution_id` en repositorios y validación estricta de sesión.	**Mitigado en Código**
RSK-02	Saturación de base de datos en fechas de cierre masivo de notas.	Medio	Alta	Conexiones asíncronas con pool `asyncpg`, caché en Redis y arquitectura preparada para réplicas de lectura.	**Preparado para Carga**
RSK-03	Falla en despacho de invitaciones por restricciones de filtros anti-spam en correos.	Medio	Media	Implementación de registro de activación en base de datos y enlaces recuperables por el administrador.	**Mitigado en Flujo**
RSK-04	Baja conectividad o micro-cortes en sedes educativas rurales.	Alto	Media	Arquitectura SPA sin dependencias externas en tiempo de ejecución y diseño CSS liviano.	**Optimizada en Red**
RSK-05	Reticencia al cambio por parte de docentes habituados a sistemas privativos previos.	Medio	Media	Diseño de interfaz intuitiva basada en planillas visuales familiares y manuales interactivos de usuario.	**Atendido en UX**

25. Recomendaciones Técnicas y Hoja de Ruta Propuesta

1. **Mesas de Trabajo Técnicas Bilaterales:** Instalar una mesa de trabajo periódica entre el equipo técnico de PEVN y los especialistas de la Oficina de Tecnología del MEN para revisar a fondo el código fuente y las pruebas.
2. **Definición de Contratos de Interoperabilidad con SIMAT:** Establecer una especificación OpenAPI estándar para el intercambio estructurado de matrículas y novedades de estudiantes.
3. **Auditoría de Ciberseguridad Independiente:** Someter la plataforma a pruebas de intrusión (*pentesting*) de caja negra y caja gris coordinadas por el equipo de seguridad digital del MEN.
4. **Incorporación como Bien Público Digital:** Evaluar la transferencia del código fuente y los activos tecnológicos al Estado bajo licencia de código abierto (ej. Apache 2.0 o GNU AGPLv3), garantizando soberanía tecnológica y ahorro presupuestal continuo.

26. Aspectos Sujetos a Validación Institucional del MEN

Sección Mandatoria de Evaluación y Dictamen Institucional: Los siguientes aspectos corresponden a materias técnicas, jurídicas y de política pública que se someten a la exclusiva consideración, validación y dictamen de las dependencias competentes del Ministerio de Educación Nacional. El presente documento no presupone conformidad ni cumplimiento definitivo, sino que identifica las áreas clave sujetas a evaluación formal:

1. **Gobernanza y Titularidad Tecnológica:**

- Determinación del modelo de gobernanza para la custodia, mantenimiento y evolución del código fuente de PEVN.
- Definición de esquemas de propiedad intelectual y cesión de derechos o licenciamiento como Bien Público Digital para el Estado colombiano.

2. **Rol de Responsable y Encargado del Tratamiento de Datos Personales:**
- Formalización de los roles jurídicos bajo la Ley 1581 de 2012 y el Decreto 1377 de 2013 (si el MEN asumirá la calidad de Responsable del Tratamiento y las instituciones la de Encargados, o el modelo aplicable a las entidades territoriales).
- Aprobación de la Política de Tratamiento de Información y protocolos de atención a derechos ARCO para la comunidad educativa.

3. **Tratamiento Especial de Datos de Menores de Edad:**
- Validación jurídica y técnica de los consentimientos informados de padres o acudientes para el registro de estudiantes en plataformas digitales oficiales.

4. **Clasificación de la Información y Seguridad Digital:**
- Clasificación de los repositorios y datos conforme a la Ley de Transparencia y del Derecho de Acceso a la Información Pública Nacional (Ley 1712 de 2014).
- Verificación del cumplimiento del Modelo de Seguridad y Privacidad de la Información (MSPI) de MinTIC y lineamientos del Gobierno Digital.

5. **Gestión de Identidades e Integración con Sistemas Nacionales:**
- Evaluación de la viabilidad de integrar el sistema de autenticación con la Carpeta Ciudadana Digital o proveedores de identidad del Estado.
- Validación de los mecanismos de aprovisionamiento de cuentas y recuperación de credenciales directivas.

6. **Interoperabilidad Oficial con SIMAT, DUE y SINEB:**
- Definición de la arquitectura técnica, protocolos de seguridad y credenciales para el intercambio transaccional de datos de matrícula, sedes y evaluación con los sistemas misionales del MEN.

7. **Accesibilidad e Inclusión Digital:**
- Realización de auditorías de accesibilidad formal bajo la Norma Técnica Colombiana NTC 5854 y las directrices WCAG 2.1 en nivel AA para garantizar el acceso a usuarios en condición de discapacidad.

8. **Disponibilidad, Continuidad y Residencia de Datos:**
- Homologación de los acuerdos de nivel de servicio (SLA), planes de continuidad de negocio (BCP) y recuperación ante desastres (DRP) en la infraestructura de computación en la nube que el MEN destine.
- Garantía de residencia de los datos educativos dentro del territorio nacional o en infraestructuras que cumplan con los estándares exigidos por la Superintendencia de Industria y Comercio (SIC).

9. **Criterios de Aceptación Técnica y Autorización de Piloto:**
- Emisión formal de los criterios técnicos que deberá satisfacer la plataforma para obtener la autorización de inicio del piloto experimental en colegios oficiales.

27. Glosario de Términos, Anexos, Archivos Fuente e Índice de Evidencias

27.1. Glosario Técnico e Institucional

- **Anti-IDOR (Insecure Direct Object Reference Mitigation):** Salvaguardas en la lógica de control de acceso que impiden la manipulación de identificadores en peticiones web para acceder a recursos de otros tenants.
- **Argon2id:** Algoritmo criptográfico moderno de derivación de claves y hashing de contraseñas, altamente resistente a ataques con unidades de procesamiento gráfico (GPU).
- **Asyncpg:** Controlador asíncrono en Python de alto rendimiento para interactuar con bases de datos PostgreSQL mediante el protocolo de red nativo.
- **BigBlueButton (BBB):** Plataforma de conferencias web de código abierto orientada específicamente a casos de uso pedagógicos y colaboración interactiva.
- **DIVIPOLA:** División Político-Administrativa de Colombia estandarizada por el DANE.
- **DUE:** Directorio Único de Establecimientos Educativos administrado por el MEN.
- **FastAPI:** Marco web asíncrono moderno en Python de alto rendimiento para la construcción de APIs REST.
- **JWT (JSON Web Token):** Estándar de seguridad (RFC 7519) para la transmisión compacta y verificada de identidades en formato JSON.

- **Multi-Tenant:** Patrón de arquitectura donde una única solución atiende de forma aislada e independiente a múltiples colegios o instituciones.
- **Pydantic v2:** Biblioteca de análisis y validación de datos en Python que garantiza tipado estricto y sanitización de cargas maliciosas.
- **RBAC (Role-Based Access Control):** Control de acceso basado en roles que vincula permisos atómicos a responsabilidades funcionales.
- **SIMAT:** Sistema Integrado de Matrícula oficial del Ministerio de Educación Nacional de Colombia.
- **SQLAlchemy 2.0:** Mapeador objeto-relacional (ORM) de estándar industrial para la persistencia transaccional en bases de datos relacionales.

27.2. Índice de Archivos Fuente y Evidencia en Repositorio

Para la auditoría directa del equipo técnico del MEN, se relacionan los archivos fuente clave en el repositorio:

- **Enrutador y API Central:** `backend/app/main.py`, `backend/app/api/v1/router.py`
- **Mecanismos de Ciberseguridad:** `backend/app/core/security.py`, `backend/app/api/deps.py`
- **Modelos de Base de Datos y RBAC:** `backend/app/models/role.py`, `backend/app/models/user.py`, `backend/app/models/academic.py`, `backend/app/models/territorial.py`
- **Servicios de Negocio Aislados:** `backend/app/services/institution_service.py`, `backend/app/services/rector_service.py`, `backend/app/services/grade_service.py`, `backend/app/services/bbb_service.py`
- **Fixture de Pruebas y Hardening de Teardown:** `backend/tests/conftest.py` (cierre limpio de motores, restablecimiento de dependencias y sanitización de errores)
- **Suite de Pruebas Automatizadas:**
- `backend/tests/test_teardown_hardening.py` (13 pruebas de ciclo de vida seguro)
- `backend/tests/test_census_analyzer.py` (12 pruebas de validación de censo)
- `backend/tests/test_institution_provisioning.py` (17 pruebas de aprovisionamiento)
- `backend/tests/test_nta10_rector_provisioning.py` (15 pruebas de directivos)
- `backend/tests/test_database_integration.py` (83 pruebas de integración PG15)
- **Script de Auditoría de Documentación:** `scripts/audit_documentation.py` (41 comprobaciones automatizadas aprobadas al 100%)
- **Aplicación Frontend:** `src/App.tsx`, `src/pages/`, `src/components/`
- **Compiladores PDF:** `scripts/generate_government_pdfs.py`

Fin del Informe Técnico Integral.

Elaborado con los más altos estándares de transparencia, rigor de ingeniería y compromiso con la educación pública colombiana.